

Active (능동수집)

(레지스트리 서버 & DNS 서버 질의)

****레지스트리 서버** : 인터넷 도메인 시스템의 가장 상위 계층에서 도메인의 중앙 기록을 관리하는 핵심 서버

Zone Transfer (AXFR)

: DNS 서버 간에 도메인 영역(Zone)에 대한 모든 정보를 복사하는 과정입니다. 여기서 AXFR(**Authoritative Xfer**)은 이 전체 복사 요청을 나타내는 쿼리 타입입니다.

기능 및 목적

1. 목적: DNS 환경에서 **주(Primary) DNS** 서버와 보조(**Secondary**) DNS 서버 간에 데이터를 동기화하는 데 사용됩니다.
2. 작동 방식:
 - 주 서버(마스터)가 특정 도메인의 모든 DNS 레코드(A 레코드, MX 레코드, CNAME 등)를 가지고 있습니다.
 - 보조 서버(슬레이브)는 주 서버에게 **AXFR** 요청을 보내 존 전체를 복사해 옵니다.
 - 이를 통해 보조 서버는 주 서버와 동일한 정보를 가지고 질의에 응답할 수 있게 됩니다.

보안 문제점

존 트랜스퍼는 원래 **DNS** 시스템의 안정성을 위해 설계되었지만, 보안상 가장 위험한 정보 수집 방법 중 하나로 간주됩니다.

- 문제: 만약 **DNS** 서버가 특정 **IP** 주소(보조 서버의 **IP**)로 제한하지 않고 외부의 누구에게나 **AXFR** 요청을 허용한다면, 공격자는 해당 도메인의 모든 내부 네트워크 정보를 통째로 얻을 수 있습니다.
- 노출되는 정보:
 - 모든 서브도메인: 웹 서버, 메일 서버, 내부 개발 서버 등 모든 호스트 이름.
 - 내부 **IP** 주소: 외부에 노출되어서는 안 될 사설망 내의 장치 **IP** 주소.
- 원리:
 - a. secondary DNS 가 primary DNS에게 **AXFR Query** 를 요청
 - b. 공격자는 해당 도메인의 **NS** 정보 파악
 - c. 공격자는 해당 네임서버로 **AXFR** 쿼리를 직접 보냄
 - d. 서버에 접근 제어(**ACL**)이 없으면 서버는 공격자에게 도메인의 모든 레코드 (**A**, **MX**, **CNAME**, **TXT** 등) 을 전송
 - e. 공격자는 숨겨진 내부서버 목록과 **IP** 주소를 한번에 획득

Subdomain Enumeration

: 특정 도메인에 연결된 모든 서브도메인을 찾아서 숨겨진 서비스나 취약한 자산이 존재하는지 확인하는 보안 정보수집 과정

: 서브도메인 중에는 보안 패치가 미흡한 오래된 시스템이나 테스트 서버가 포함되어 있을 수 있으며, 이것이 공격자가 침투할 수 있는 취약한 경로가 될 가능성이 높음

취약한 **3차** 도메인 설정

: 보안이 철저한 메인웹사이트와 달리 서브도메인은 보안이 취약한 경우가 많음

- i. 개발 / 테스트서버 : **dev, test, stage** 등의 이름으로 만들어두고 디버깅 모드를 켜두거나 보안 패치를 안한경우가 많음
- ii. 관리자 페이지 : **admin, manager, vpn** 등 관리자만 접속해야 할 페이지가 인터넷에 노출되어 있을수 있음
- iii. 구버전 시스템 : **old, v1, backup** 등 예전 프로젝트나 구버전 시스템이 방치되어 좀비서버로 남아있을 수 있음
 - **www.example.com** (일반 웹사이트)
 - **mail.example.com** (메일 서버)
 - **dev.example.com** (개발 환경)
 - **test.example.com** (테스트 환경)
 - **api.example.com** (API 서버)

서브도메인 패시브 & 액티브 방식

a. 패시브 방식 :

i. **CT** 로그 조회 > 합법

1. 웹사이트가 **HTTPS**(보안 연결)를 적용하려면 인증서를 발급받아야 함.
이 인증서 발급 기록은 의무적으로 ****공개된 로그 서버(CT Log)****에 저장됨
2. 방법: 공격자는 이 공개 장부를 조회하여 인증서 발급여부를 확인할 수 있음
3. 사이트: `crt.sh` 같은 곳에서 검색만 하면 바로 확인 가능

ii. 검색 엔진 (**Search Engines**)

1. 원리: 구글이나 네이버 같은 검색 로봇(**Crawler**)은 우리가 모르는 사이에 서브도메인을 방문해서 데이터를 저장해둠
2. 방법: **Google Dorking**(`site:example.com -www`)을 사용하여 구글이 알고 있는 페이지를 질의

iii. **DNS** 기록 아카이브

1. 원리: `VirusTotal`, `DNSDumpster` 같은 보안 사이트들은 과거의 **DNS** 기록을 데이터베이스화해서 가지고 있습니다. 현재는 사라졌지만 과거에 썼던 도메인도 찾을 수 있습니다.

b. 액티브 방식 :

i. 사전 대입 (**Dictionary Attack**)

1. 원리: 사람들이 자주 쓰는 서브도메인 단어장(Wordlist)을 준비
2. 방법: DNS 서버에게 모든 단어장 질의
3. 도구: `dnsenum`, `Sublist3r`

ii. 변형 (**Permutation/Alteration**)

1. 원리: 이미 찾은 서브도메인을 변형해서 새로운 것을 찾음
2. 예시: `dev.example.com`을 찾았다면, 컴퓨터가 자동으로 `dev1`, `dev-test`, `dev-staging` 등을 조합해서 다시 질의

=> `DNSenum`과 `DNSrecon` 이 자동으로 dictionary Attack을 통한 BruteForce 수행 및 Zone tranfer 수행